

day-41-brain-security-sweep

Day 41 â Brain Security Sweep

Date: 2026-05-09

Status: PASS

Blocker class: NONE

Lane

Brain / Build-Wiki / Farmer security sweep.

Objective

Remove or guard owner-facing raw path, secret-like value, unapproved vault, SMB, Fork 2, and external-farmer exposure in the Brain / Build-Wiki / Farmer surfaces without changing '.env', auth, memory, governance, or execution policy.

Inventory

Reviewed active Brain / Farmer surfaces:

- 'GET /api/bridge/brain-sync/status'
- 'GET /api/bridge/brain-sync/knowledge-report'
- 'GET /api/bridge/brain-sync/build-wiki/status'
- 'GET /api/bridge/brain-sync/build-wiki/files'
- 'GET /api/bridge/brain-sync/build-wiki/files/:type/:name'
- 'GET /api/bridge/brain-sync/build-wiki/logs'
- 'GET /api/bridge/agent-zero/obsidian'
- 'GET /api/bridge/agent-zero/mempalace'

Confirmed source-only local path constants still exist where needed for local adapter resolution, but owner-facing route responses must not expose those values.

Implemented

Found and fixed one concrete owner-facing leak risk:

- Build-Wiki file metadata and detail helpers retained internal 'full_path'.
- The file listing route already ran the bridge sanitizer, but still returned 'full_path' as an owner-facing field.
- The file detail route returned 'readFileSafe()' directly, which could expose 'full_path', raw local path text inside content, or secret-shaped strings inside content.

Changes made:

- Added owner-safe file view helpers that omit 'full_path' and expose only a safe 'path_ref'.
- Updated Build-Wiki file listing to map metadata through the owner-safe helper.
- Updated Build-Wiki file detail route to map through the owner-safe helper and sanitize the full response payload.
- Added tests for both list and detail routes.

Files Changed

- 'src/lib/build-wiki-files.ts'
- 'src/app/api/bridge/brain-sync/build-wiki/files/route.ts'
- 'src/app/api/bridge/brain-sync/build-wiki/files/route.test.ts'
- 'src/app/api/bridge/brain-sync/build-wiki/files/[type]/[name]/route.ts'
- 'src/app/api/bridge/brain-sync/build-wiki/files/[type]/[name]/route.test.ts'

Routes Changed

- 'GET /api/bridge/brain-sync/build-wiki/files'
- 'GET /api/bridge/brain-sync/build-wiki/files/:type/:name'

UI / Owner-Facing Behavior

- File metadata no longer exposes 'full_path'.
- File detail responses no longer expose 'full_path'.
- Raw local path text is redacted as '<redacted-path>'.
- Secret-shaped values are redacted as '<redacted-secret>'.
- 'relative_path' remains because it is a vault-relative label used by the UI, not a host path.
- Read-only behavior is unchanged.

Runtime / Service Behavior

- No Build-Wiki execution was triggered.
- No Farmer run was started.
- No SMB, Fork 2, external farmer, or second vault behavior was enabled.
- Allowed service literal remains only: 'opencloud-docs-farmer.service'.
- Mission Control runtime restarted on source commit '9f6d8c5d6e2a906302a85378d6de3b151bbc77a4'.
- Runtime PID after restart: '72421'.
- Runtime bind: '127.0.0.1:3337'.

Validation

- 'git diff --check': PASS
- 'pnpm run typecheck': PASS
- 'pnpm run build': PASS
- 'pnpm test': PASS â 163 files / 1336 tests
- 'node scripts/check-protected-file-invariants.mjs': PASS
- Staged secret scan: PASS
- '.env' diff: clean

During validation, stale generated Next type duplicates under '.next/types' with ' 2.ts' suffixes were removed. These were generated build artifacts only, not source or owner data.

Runtime Proof

Proof artifact:

- 'runtime/day-41-brain-security-sweep-proof.json'

Authenticated runtime response scan:

- Endpoints checked: 7
- Raw local path violations: 0
- Secret-shaped value violations: 0
- SMB / Fork 2 / external farmer / second vault violations: 0
- 'GET /login': 200
- Unauthenticated 'GET /api/bridge/brain-sync/build-wiki/files?type=all&limit=1': 401

Note: authenticated smoke used the runtime API key and a non-secret placeholder session cookie only to pass the proxy prefilter; route-level authorization still validated the API key. No credential value was printed.

Commit / Push

Source commit:

- '9f6d8c5' â 'fix(brain): redact build wiki file paths'

Push:

- 'origin/to-knowledge-mc': pushed

Rollback

Rollback source change:

```
““bash  
git revert 9f6d8c5  
““
```

Safety Confirmation

- No '.env' changes.
- No secrets printed.
- No auth weakening.
- No public local exposure added.
- No memory or governance changes.
- No Build-Wiki execution.
- No SMB/Fork 2.
- No external farmers.
- No second vault.

Next Day Started

Day 42 â Brain / Farmer final closeout is now the active next lane.